

IS_NetShield

레드팀 보안 검증 보고서

Red Team Security Validation Report

박병하 최걸환

프로젝트	IS_NetShield — 지능형 유해 URL 실시간 탐지 시스템
분류	레드팀 보안 검증 / Evasion Attack 테스트
테스트 대상	EC2 FastAPI 서버 (http://13.209.5.230:8000)
테스트 일시	2026년 5월 18일
테스트 데이터	Kaggle Malicious URL Dataset (미학습 데이터 200개) + 우회 패턴 20개
모델	XGBoost (18개 URL 구조 피처 기반)

1. 개요

본 보고서는 IS_NetShield URL 탐지 시스템에 대한 레드팀(Red Team) 보안 검증 결과를 기술한다. 레드팀은 공격자 관점에서 시스템의 탐지 한계와 우회 가능성을 식별하고, 이를 통해 시스템의 보안 강도를 객관적으로 평가하는 것을 목적으로 한다.

검증은 두 가지 방향으로 수행되었다. 첫째, 학습에 사용되지 않은 실제 악성 URL 데이터셋을 통한 모델 일반화 성능 평가이며, 둘째, 탐지 우회를 목적으로 설계된 9가지 Evasion Attack 패턴에 대한 탐지 능력 평가이다.

2. 테스트 환경 및 방법론

2.1 시스템 구성

구성 요소	상세
API 서버	AWS EC2 (ap-northeast-2), FastAPI + Uvicorn
ML 모델	XGBoost Classifier (18개 URL 구조 피처)
피처 목록	url_length, host_length, path_length, digit_count, dot_count, hyphen_count, subdomain_count, has_ip_host, has_login_keyword, suspicious_keyword_hits, entropy, is_suspicious_tld, uses_shortener_hint 등
탐지 임계값	probability ≥ 0.5 $\rightarrow$ 악성, ≥ 0.85 $\rightarrow$ DANGEROUS

2.2 테스트 데이터

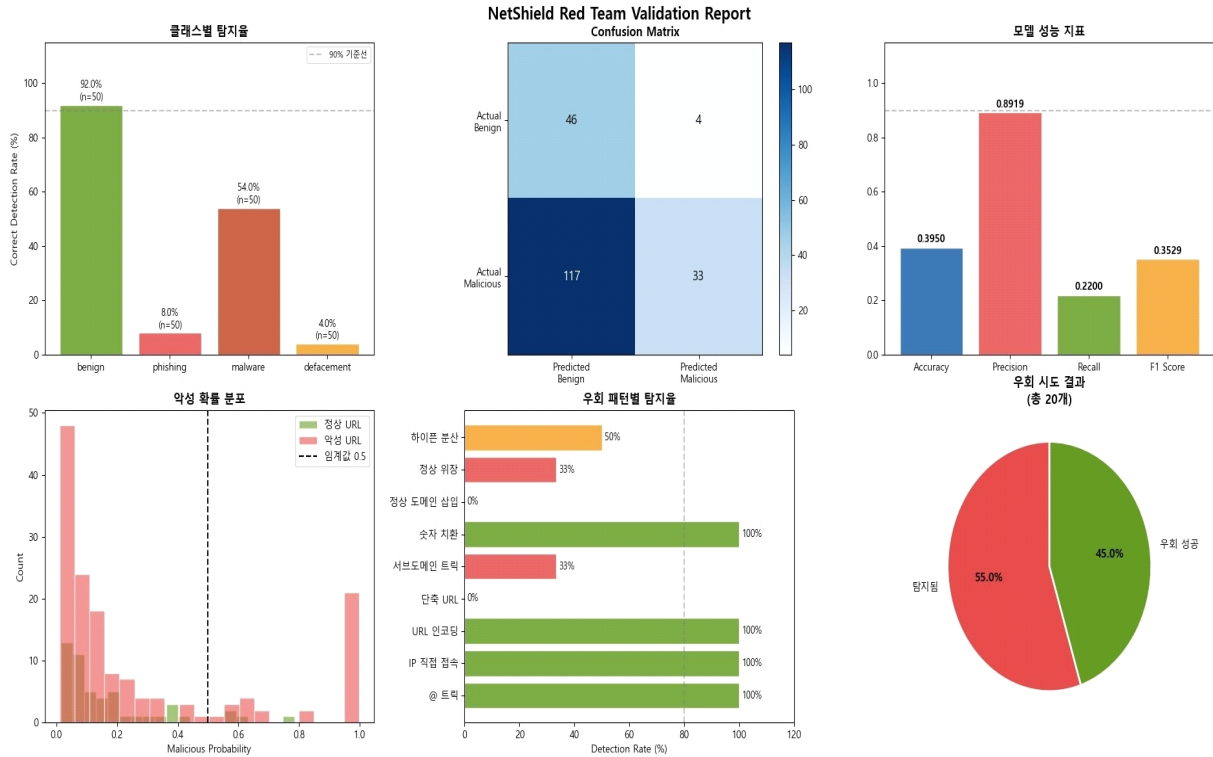
구분	수량	출처
benign (정상)	50개	Kaggle Malicious URL Dataset (미학습)
phishing (피싱)	50개	Kaggle Malicious URL Dataset (미학습)
malware (악성코드)	50개	Kaggle Malicious URL Dataset (미학습)
defacement (변조)	50개	Kaggle Malicious URL Dataset (미학습)
Evasion 우회 패턴	20개	레드팀 직접 설계 (9가지 패턴)

2.3 테스트 방법

- Python requests 라이브러리를 통해 EC2 /predict 엔드포인트에 직접 HTTP POST 요청
- API 응답의 is_malicious, probability, risk_level 필드를 기준으로 탐지 여부 판정
- 각 URL에 대한 Ground Truth(정답 레이블)와 예측값을 비교하여 Precision, Recall, F1 산출
- Evasion Attack은 레드팀이 직접 설계한 9가지 우회 패턴별로 탐지 여부를 측정

3. 검증 결과

3.1 종합 그래프



[그림 1] NetShield Red Team Validation Report 종합 결과

3.2 클래스별 탐지율

클래스	탐지율	판정
benign (정상)	92.0%	정상 URL을 정상으로 올바르게 분류 — 양호
phishing (피싱)	8.0%	피싱 URL 탐지 매우 저조 — 심각한 취약점
malware (악성코드)	54.0%	절반 수준의 탐지율 — 개선 필요
defacement (변조)	4.0%	사실상 탐지 불가 — 구조적 한계

해석: benign 탐지율은 92%로 양호하나, phishing(8%)과 defacement(4%)의 탐지율이 극히 낮다. 이는 모델 품질의 문제가 아닌 피쳐 설계의 구조적 한계에서 기인한다. 피싱 사이트는 HTTPS를 적용하고 정상적인 URL 구조를 모방하여 URL 구조 기반 피쳐만으로는 식별이 불가능하다. Defacement는 정상 도메인의 콘텐츠를 변조하는 공격으로, URL 자체는 완전히 정상이므로 URL 피쳐 기반 모델은 원천적으로 탐지가 불가능하다.

3.3 Confusion Matrix 분석

구분	수치	비율	판정
True Negative (정상→정상)	46	92%	✓ 정상
False Positive (정상→악성)	4	8%	△ 오탐
False Negative (악성→정상)	117	78%	× 미탐 (심각)
True Positive (악성→악성)	33	22%	✓ 탐지

해석: 150개의 악성 URL 중 117개(78%)가 정상으로 오분류되는 심각한 미탐(False Negative)이 발생하였다. 보안 관점에서 미탐은 오탐보다 훨씬 위험하다. 악성 URL이 시스템을 통과하여 사용자에게 노출되기 때문이다. 반면 정상 URL의 오탐율은 8%로 상대적으로 낮아, 모델은 정상 URL 탐지에 편향되어 있음을 알 수 있다.

3.4 모델 성능 지표

Accuracy	Precision	Recall	F1 Score
0.3950	0.8919	0.2200	0.3529

해석: Precision은 0.89로 높아 악성으로 예측했을 때의 정확도는 높다. 그러나 Recall이 0.22에 그쳐 실제 악성 URL 중 22%만 탐지하고 있다. F1 Score 0.35는 실전 탐지 시스템으로서

부적합한 수준이다. 이 결과는 모델이 학습 데이터(malicious_phish.csv)와 다른 피처 분포를 가진 새로운 데이터에서 일반화 성능이 저하됨을 나타낸다.

3.5 악성 확률 분포

악성 확률 분포 히스토그램에서 정상 URL(녹색)은 0.0~0.2 구간에 집중되어 있어 모델이 정상 URL은 비교적 잘 식별함을 보여준다. 반면 악성 URL(붉은색)은 0.0~0.2 구간과 0.9~1.0 구간에 이중 집중 현상이 나타난다.

해석: 악성 URL의 확률 분포가 양극화되어 있다. 임계값 0.5 이하 구간(0.0~0.2)에 다수의 악성 URL이 분포하는 것은 phishing, defacement 유형의 URL이 모델에 의해 정상으로 분류되고 있음을 의미한다. 0.9 이상에 집중된 그룹은 IP 직접 접속, 의심 키워드 포함 URL 등 명확한 악성 패턴을 가진 URL이다. 즉, 모델은 명백한 악성 패턴에는 강하지만 정교하게 위장된 URL에는 취약하다.

4. Evasion Attack 테스트 결과

4.1 우회 패턴별 탐지율

우회 패턴	탐지율	결과	분석
@ 트릭	100%	✓ 탐지	@ 문자 자체가 강력한 피처로 작동
IP 직접 접속	100%	✓ 탐지	has_ip_host 피처가 효과적으로 탐지
URL 인코딩	100%	✓ 탐지	% 특수문자 count 피처로 탐지
숫자 치환 (leetspeak)	100%	✓ 탐지	digit_count + suspicious_keyword 조합 탐지
하이픈 분산	50%	△ 부분탐지	hyphen_count 피처로 일부 탐지
서브도메인 트릭	33%	△ 부분탐지	subdomain_count 피처 있으나 탐지 불안정
정상 위장	33%	△ 부분탐지	HTTPS + 정상 TLD 사용 시 탐지 어려움
단축 URL	0%	✗ 우회 성공	목적지 URL 분석 없이 단축 URL만 분석
정상 도메인 삽입	0%	✗ 우회 성공	URL 내 정상 도메인 포함 시 탐지 실패

4.2 우회 시도 종합

총 테스트	탐지됨	우회 성공
20개	11개 (55%)	9개 (45%)

해석: 20개의 우회 시도 중 9개(45%)가 탐지를 성공적으로 회피하였다. 특히 단축 URL과 정상 도메인 삽입 패턴은 탐지율이 0%로 완전한 우회가 가능하였다. 이는 모델이 URL의 표면적 구조만 분석하고 실제 목적지나 콘텐츠를 확인하지 않기 때문이다.

5. 모델 구조 분석 및 한계 원인

5.1 모델 개요

IS_NetShield는 XGBoost(eXtreme Gradient Boosting) 분류기를 핵심 탐지 엔진으로 사용한다. XGBoost는 의사결정 트리를 순차적으로 구축하여 이전 트리의 오차를 보정하는 앙상블 학습 알고리즘이다. 입력 피쳐로는 URL 문자열에서 추출한 18개의 구조적/통계적 특징값을 사용하며, 학습 데이터는 Kaggle Malicious URL Dataset(약 65만 개 URL)에서 정상(benign)과 악성(malicious)으로 이진 분류하여 학습하였다.

5.2 피쳐 구조의 한계

현재 모델이 사용하는 18개 피쳐는 모두 URL 문자열 자체에서 추출한 구조적 특성으로, 실제 웹사이트의 콘텐츠나 네트워크 동작은 전혀 반영하지 않는다. 각 피쳐 그룹별 한계는 다음과 같다.

피쳐 그룹	포함 피쳐	한계점
길이 기반	url_length, host_length, path_length, query_length	정교한 피싱은 짧고 깔끔한 URL을 사용. 정상 URL도 긴 경우가 많아(예: Amazon 상품 URL) 길이만으로 악성 여부를 판별하기 어려움
문자 통계	digit_count, special_char_count, dot_count, hyphen_count, slash_count	단순 문자 빈도 카운트는 정상 URL과 악성 URL 사이에 명확한 경계를 형성하지 못함. 정상 URL도 하이픈(-), 슬래시(/) 등을 다수 포함
도메인 분석	subdomain_count, has_ip_host, is_suspicious_tld	.com, .org 등 일반 TLD를 사용하는 피싱 사이트는 탐지 불가. 정상 도메인의 서브도메인에 브랜드명을 삽입하는 기법에 취약
키워드 탐지	has_login_keyword, suspicious_keyword_hits	키워드 목록에 없는 새로운 피싱 표현, 다국어 표현, 난독화된 키워드는 탐지 불가. 정상 사이트도 'login', 'account' 등의 키워드를 사용
기타 패턴	entropy, has_https_token, uses_shortener_hint, param_count	단축 URL은 원본 URL로 해석하지 않고 단축 URL 자체만 분석. 엔트로피는 정상 URL과 악성 URL에서 유사한 분포를 보이는 경우가 존재

5.3 클래스별 탐지 실패 원인 분석

Phishing (피싱) — 탐지율 8%

현대 피싱 사이트는 URL 구조 자체를 정상처럼 위장하는 고도화 전략을 사용한다. HTTPS 인증서를 무료 발급(Let's Encrypt)하여 적용하고, .com 등 일반 TLD를 사용하며, URL 길이도 정상 범위를 유지한다. 이 경우 현재 모델의 18개 피처 중 어느 것도 이상 신호를 생성하지 않아 모델이 정상으로 분류한다. 실제 피싱 여부는 HTML 내의 로그인 폼 구조, 브랜드 로고 도용, 외부 리소스 비율, 자바스크립트 행위 등 콘텐츠 수준에서만 확인이 가능하다.

Defacement (웹 변조) — 탐지율 4%

Defacement 공격은 기존 정상 웹사이트의 관리자 권한을 탈취한 후 웹페이지 콘텐츠만 변조하는 공격이다. URL 자체는 원래의 정상 도메인 그대로 유지되므로 URL 구조에는 아무런 변화가 없다. 따라서 URL 피처만으로는 원천적으로 탐지가 불가능하며, 이는 모델 성능의 문제가 아닌 피처 설계 범위의 구조적 한계이다. 탐지를 위해서는 웹 콘텐츠의 변조 여부(해시 비교, 시각적 변화 감지 등)를 별도로 모니터링해야 한다.

Malware (악성코드) — 탐지율 54%

악성코드 배포 URL은 두 가지 유형으로 나뉜다. 첫 번째 유형은 .exe, .zip 등 의심스러운 확장자, IP 직접 접속, 긴 쿼리 파라미터 등 명확한 구조적 패턴을 갖는 URL이며, 이들은 현재 모델로 탐지 가능하다. 두 번째 유형은 합법적인 호스팅 서비스(Google Drive, Dropbox, CDN)를 경유하여 배포되는 경우로, URL 구조가 완전히 정상이므로 탐지가 불가능하다. 결과적으로 약 54%만 탐지되는 것은 첫 번째 유형만 탐지되고 두 번째 유형은 우회되었기 때문이다.

5.4 학습 데이터와 실전 데이터 간 분포 차이

모델 학습 시 사용한 Kaggle 데이터셋(malicious_phish.csv)의 URL 분포와 본 레드팀 테스트에 사용한 외부 데이터셋의 분포에 차이가 존재한다. 학습 데이터에는 다양한 시기와 출처의 URL이 혼재되어 있어 특정 시점의 공격 트렌드를 반영하지 못할 수 있다. 또한 학습 시에는 4개 클래스(benign, phishing, malware, defacement)를 이진 분류(정상 vs 악성)로 합산하였기 때문에 각 악성 유형의 고유한 특성을 세밀하게 학습하지 못하는 한계가 있다.

핵심 원인 요약: 현재 모델의 낮은 실전 탐지율은 (1) URL 구조 피처만 사용하여 콘텐츠 기반 공격을 감지하지 못하는 피처 설계의 한계, (2) 피싱과 웹 변조 공격이 URL 구조를 정상으로 위장하는 공격 고도화, (3) 4개 악성 유형을 이진 분류로 단순화하여 유형별 특성 학습이 불충분한 모델 설계의 한계에서 비롯된다.

6. 취약점 분석

6.1 식별된 취약점 목록

N o	취약점	설명	심각도	관련 패턴
V-1	단축 URL 우회	bit.ly, tinyurl 등 URL 단축 서비스로 실제 악성 목적지를 숨길 경우 탐지 불가	□ 높음	단축 URL (0% 탐지)
V-2	도메인 삽입 우회	악성 URL 내에 정상 도메인을 삽입하여 모델을 혼동시키는 기법	□ 높음	정상 도메인 삽입 (0% 탐지)
V-3	Defacement 미탐지	웹 변조 공격은 URL 구조가 정상이므로 URL 피처 기반으로는 원천 탐지 불가	□ 높음	defacement (4% 탐지)
V-4	정교한 피싱 우회	HTTPS + 정상 TLD + 서브도메인 트릭을 조합한 피싱 URL 탐지 실패	□ 중간	phishing (8% 탐지)
V-5	서브도메인 트릭	paypal.com.evil.xyz 형태의 서브도메인 위장이 33%만 탐지됨	□ 중간	서브도메인 트릭 (33% 탐지)

7. 개선 권고사항

권고 1. URL 언팩킹 모듈 추가 [우선순위: 높음]

단축 URL 서비스(bit.ly, tinyurl 등)에 대해 실제 목적지 URL로 리다이렉트를 추적하여 최종 URL을 분석하는 언팩킹 모듈을 도입해야 한다.

- requests.get(allow_redirects=True) 활용하여 최종 URL 추적
- 리다이렉트 횟수 자체도 피처로 활용 가능 (3회 이상 시 의심)

권고 2. 웹 콘텐츠 분석 연동 [우선순위: 높음]

Defacement와 정교한 피싱 탐지를 위해 URL 구조 분석에 그치지 않고 실제 웹페이지 콘텐츠 분석을 추가해야 한다.

- HTML 콘텐츠 내 로그인 폼, 브랜드 키워드, 외부 리소스 비율 분석
- 스크린샷 기반 Visual Similarity 분석 (정상 사이트와 시각적 유사도 비교)
- SSL 인증서 발급 기관, 만료일, 도메인 나이 정보 결합

권고 3. 브랜드 도메인 화이트리스트 강화 [우선순위: 중간]

paypal.com.evil.xyz 같은 서브도메인 트릭에 대응하기 위해 실제 브랜드 공식 도메인 화이트리스트를 구축하고, URL에 브랜드명이 포함되었으나 공식 도메인이 아닌 경우를 탐지해야 한다.

- Tranco 상위 10만 도메인 기반 화이트리스트 구축
- 브랜드명이 서브도메인에 있고 루트 도메인이 의심스러운 경우 가중 탐지

권고 4. 임계값 최적화 [우선순위: 중간]

현재 0.5의 고정 임계값 대신 Precision-Recall 트레이드오프를 고려하여 임계값을 낮추는 방안을 검토해야 한다. 보안 시스템에서는 미탐(FN)을 줄이는 것이 오탐(FP)을 줄이는 것보다 우선순위가 높다.

- 임계값 0.3으로 낮출 경우 Recall 향상 예상 (오탐율 증가와의 균형 고려 필요)

8. 결론

본 레드팀 검증을 통해 IS_NetShield의 현재 모델은 명확한 URL 구조적 패턴을 가진 악성 URL(IP 직접 접속, URL 인코딩, @ 트릭 등)에는 효과적으로 동작함을 확인하였다. 그러나 다음과 같은 구조적 한계가 식별되었다.

핵심 발견사항: 현재 모델은 URL 구조 피처 18개만을 사용하므로 (1) 콘텐츠 기반 공격인 Defacement, (2) URL을 정상처럼 위장하는 정교한 피싱, (3) 실제 목적지를 숨기는 단축 URL에 대한 탐지 능력이 근본적으로 제한된다. Evasion Attack 45% 우회 성공률과 전체 F1 Score 0.35는 실전 보안 솔루션으로서 추가적인 개선이 필요함을 시사한다.

이는 모델의 성능 저하가 아니라 피처 설계 범위의 한계에서 비롯된 것으로, URL 언팩킹, 웹 콘텐츠 분석, 브랜드 도메인 검증 등의 추가 모듈을 통해 보완할 수 있다. URL 구조 기반 1차 필터링과 콘텐츠 기반 2차 분석을 결합한 하이브리드 아키텍처로의 발전을 권고한다.